

CSPTF

Crypto Security Penetration Testing Framework

CSPTF

Framework integral y seguro para pentesting autorizado de ecosistemas de activos digitales

Paper técnico y propuesta metodológica

Autor: Edwin Javier Peñuela Camacho

Versión: 0.1.0-draft

Fecha: 2026-07-31

Licencia: Apache-2.0

BORRADOR FUNDACIONAL - NO ES CERTIFICACIÓN

Control del documento

Documento	CSPTF - Paper técnico
Framework version	0.1.0-draft
Estado	Borrador público fundacional
Autor inicial	Edwin Javier Peñuela Camacho
Fecha	2026-07-31
Licencia	Apache-2.0
Repositorio	https://github.com/sr-maximus/CSPTF
Limitación	No constituye certificación, garantía de seguridad, asesoría legal ni autorización para ejecutar pruebas.

Contenido

- Resumen
 - Abstract
1. 1. Introducción
 2. 2. Problema y preguntas de investigación
 3. 3. Metodología de investigación y diseño
 4. 4. Estado del arte
 5. 5. Análisis de brecha
 6. 6. Principios de diseño
 7. 7. Arquitectura de veinte dominios
 8. 8. Ciclo de evaluación
 9. 9. Reglas de compromiso y seguridad
 10. 10. Perfiles de aseguramiento y evidencia
 11. 11. Modelo preliminar de riesgo
 12. 12. Catálogos y automatización
 13. 13. Ejemplo de aplicación
 14. 14. Validación propuesta
 15. 15. Limitaciones y amenazas a la validez
 16. 16. Conclusión

Referencias

Resumen

Los ecosistemas de activos digitales combinan software, criptografía, custodia, incentivos económicos, infraestructura distribuida, servicios centralizados y obligaciones regulatorias. Esta composición amplía la superficie de ataque más allá de los contratos inteligentes y dificulta aplicar una metodología de pentesting homogénea. Este artículo presenta CSPTF (Crypto Security Penetration Testing Framework), un borrador abierto y orientado a pruebas autorizadas que integra conocimiento adversario, controles, casos de prueba, evidencia, riesgo, reporte y retest para sistemas de criptomonedas, blockchain, Web3, DeFi y CeFi.

El diseño se apoya en una revisión estructurada de estándares, knowledge bases y literatura técnica. MITRE AADAPT aporta tácticas y técnicas adversarias específicas para activos digitales [1-2]; OWASP SCSVS, SCSTG y SCWE ofrecen profundidad en requisitos, pruebas y debilidades de contratos inteligentes [3-5]; EEA EthTrust aporta requisitos de revisión para Solidity [6]; y NIST SP 800-115 proporciona disciplina para planear, ejecutar y cerrar evaluaciones técnicas [7]. La literatura académica demuestra, además, que la seguridad exige combinar análisis de código, secuencias transaccionales, incentivos, MEV, liquidez temporal y semántica cross-chain [15-27].

CSPTF v0.1 define veinte dominios, 160 controles, 240 pruebas, 100 amenazas, 100 debilidades, cuatro perfiles de aseguramiento, seis niveles de evidencia y un modelo preliminar de riesgo cripto-económico. Su principal contribución es una capa integradora, segura y trazable para evaluar el sistema completo. El documento no presenta una certificación ni afirma validación empírica definitiva: propone una agenda de revisión experta, estudios de caso, confiabilidad entre evaluadores y calibración antes de una versión estable.

Palabras clave: seguridad blockchain; criptomonedas; Web3; DeFi; CeFi; pentesting; contratos inteligentes; custodia; bridges; threat modeling.

Abstract

Digital-asset ecosystems combine software, cryptography, custody, economic incentives, distributed infrastructure, centralized services, and regulatory obligations. This composition expands the attack surface beyond smart contracts and makes consistent penetration-testing methodology difficult. This paper introduces CSPTF (Crypto Security Penetration Testing Framework), an open, safety-first draft for authorized assessment that integrates adversary behavior, controls, test cases, evidence, risk, reporting, remediation, and retesting across cryptocurrency, blockchain, Web3, DeFi, and CeFi systems.

The design is based on a structured review of standards, knowledge bases, and technical research. CSPTF v0.1 defines twenty domains, 160 controls, 240 authorized tests, 100 threat scenarios, 100 weakness patterns, four assurance profiles, six evidence levels, and a preliminary crypto-economic risk model. Its principal contribution is an integration layer for whole-system assessment rather than another smart-contract vulnerability list. This release is neither a certification nor a claim of final empirical validation. It establishes a falsifiable, machine-readable foundation for expert review, case studies, inter-rater reliability measurement, and risk calibration.

Keywords: blockchain security; cryptocurrency; Web3; DeFi; CeFi; penetration testing; smart contracts; custody; bridges; threat modeling.

Contribuciones del trabajo

#	Contribución	Descripción
1	Capa integradora	Conecta AADAPT, OWASP SCS, EEA EthTrust, NIST y literatura sin reemplazar fuentes especializadas.
2	Alcance de sistema completo	Veinte dominios on-chain, off-chain, centralizados, descentralizados, económicos y operacionales.
3	Safety-first	RoE, jerarquía de ambientes, presupuestos, stop authority, reconciliación y mainnet excepcional.
4	Evidencia y aseguramiento	AP1-AP4, E0-E5 y confianza C1-C4.
5	Riesgo cripto-económico	Finanzas, gobernanza, impacto sistémico, incentivos, composabilidad e irreversibilidad.

#	Contribución	Descripción
6	Operabilidad abierta	500 objetos de catálogo, JSON/CSV/Markdown, schemas, validadores y plantillas.

1. Introducción

La adopción de activos digitales ha convertido la seguridad en un problema socio-técnico y económico. Una transacción puede ser irreversible; un contrato puede componer de manera atómica con varios protocolos; un bridge depende de semánticas, verificadores y finalidades diferentes; una wallet puede estar protegida por hardware, MPC o procesos humanos; y una plataforma centralizada puede mantener simultáneamente libros internos, wallets, APIs, motores de órdenes y obligaciones de reserva.

En ese contexto, una auditoría limitada a código fuente puede omitir la ruta real de pérdida. De manera inversa, una evaluación tradicional de infraestructura puede no comprender invariantes on-chain, manipulación de oráculos, MEV, liquidaciones o riesgos de upgrade. El desafío no consiste únicamente en enumerar vulnerabilidades, sino en conectar activos, autoridad, estados, flujos de valor, actores, dependencias y recuperación.

MITRE AADAPT se publicó como una knowledge base de acciones adversarias en tecnologías de pagos y activos digitales, modelada a partir de ATT&CK [1-2]. OWASP Smart Contract Security estructura requisitos, debilidades y pruebas para contratos inteligentes y dApps, principalmente EVM/Solidity [3-5]. EEA EthTrust v3 define requisitos de revisión para contratos Solidity y niveles de profundidad [6]. NIST SP 800-115, aunque genérico, establece un proceso sólido de planeación, ejecución, análisis y mitigación [7]. Estas piezas son complementarias, pero no constituyen por sí solas una metodología integral de pentesting para el sistema digital completo.

CSPTF se propone como una capa de integración. Su pregunta de diseño es: ¿cómo organizar una evaluación autorizada que conserve la profundidad de fuentes especializadas, abarque capas on-chain y off-chain, considere efectos económicos y sistémicos, y produzca evidencia comparable sin prometer una seguridad absoluta?

CSPTF como capa integradora, no sustitutiva

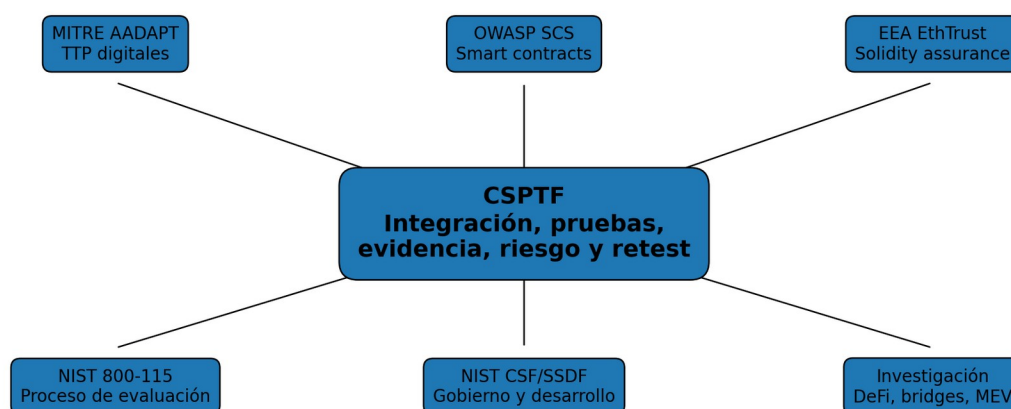


Figura 1. CSPTF integra fuentes especializadas dentro de un ciclo común de evaluación.

2. Problema y preguntas de investigación

La fragmentación metodológica produce al menos cinco problemas. Primero, el alcance puede definirse por tecnología y no por flujo de valor. Segundo, las pruebas pueden ejecutarse sin una jerarquía explícita de

ambientes seguros. Tercero, el reporte puede mezclar scanner output, observación y explotación demostrada como si tuvieran el mismo peso. Cuarto, la severidad puede ignorar incentivos, composabilidad e irreversibilidad. Quinto, los resultados de equipos diferentes son difíciles de comparar por ausencia de identificadores, evidencia y criterios homogéneos.

El trabajo plantea cuatro preguntas:

RQ1. ¿Qué capacidades cubren los principales marcos y estándares públicos aplicables a seguridad de activos digitales?

RQ2. ¿Qué capacidades quedan fuera cuando el objeto de evaluación es un sistema completo, incluyendo custodia, bridges, nodos, CEX, cloud, fraude y resiliencia?

RQ3. ¿Qué estructura permite integrar amenazas, controles, pruebas, evidencia, riesgo y retest sin duplicar fuentes especializadas?

RQ4. ¿Cómo limitar el riesgo operacional de las pruebas en sistemas con transacciones irreversibles, mercados y activos de terceros?

3. Metodología de investigación y diseño

El desarrollo siguió una metodología de diseño informada por evidencia. Se revisaron fuentes primarias organizadas en seis grupos: estándares y especificaciones oficiales; knowledge bases de amenazas; guías de testing; investigación académica; propuestas de protocolo; y regulación o guías intergubernamentales.

La inclusión exigió relevancia directa, autoría o entidad identificable, publicación estable y una contribución mapeable a arquitectura, amenaza, control, prueba, evidencia, riesgo o gobernanza. Se priorizaron fuentes primarias sobre resúmenes comerciales. La síntesis se realizó codificando cada fuente por capa del sistema, propiedad de seguridad, tipo de evidencia, comportamiento adversario y método de validación.

Este proceso es una revisión narrativa estructurada, no una revisión sistemática registrada. Por ello, la afirmación de brecha se limita a las fuentes públicas revisadas y a la fecha del estudio. No demuestra la inexistencia de metodologías privadas, inéditas o posteriores. La trazabilidad se preserva en el registro de fuentes del repositorio.

4. Estado del arte

AADAPT organiza comportamiento adversario para sistemas de gestión de activos digitales y complementa ATT&CK [1-2]. Su fortaleza está en describir objetivos y técnicas del atacante; no pretende ser un estándar de controles o una guía completa de engagement.

OWASP SCSVS proporciona requisitos verificables; SCSTG describe metodologías y casos de prueba; y SCWE enumera debilidades [3-5]. En conjunto forman una base profunda para contratos inteligentes, dApps y sistemas EVM. EEA EthTrust v3 añade requisitos para revisiones Solidity y niveles S, M y Q [6]. Estas fuentes son esenciales para CSPTF, especialmente en arquitectura, criptografía, contratos, dApps, tokens, DeFi y oráculos.

NIST SP 800-115 aporta un ciclo general de assessment [7], mientras NIST CSF 2.0 y SSDF facilitan integración con gobierno del riesgo y desarrollo seguro [8,11]. AADAPT, OWASP, EEA y NIST cubren dimensiones diferentes y deben preservarse como fuentes especializadas.

La investigación académica demuestra por qué la evaluación no puede reducirse a un único scanner. Trabajos seminales identificaron patrones y vulnerabilidades en contratos Ethereum [15-18]. Una evaluación empírica de herramientas sobre decenas de miles de contratos mostró resultados dispares y falsos positivos, reforzando la necesidad de validación experta [19]. La literatura sobre MEV y flash loans evidenció ataques cuyo núcleo es económico y composable [20-21]. Estudios de ataques reales y secuencias transaccionales ampliaron el análisis hacia comportamiento dinámico [22-23]. Investigaciones sobre EOSIO mostraron que la seguridad no es exclusiva del EVM [24]. Finalmente, trabajos recientes sobre bridges analizaron inconsistencias semánticas, monitoreo y detección cross-chain [25-27].

Fuente	Fortaleza	Límite principal
MITRE AADAPT	Tácticas y técnicas para activos digitales	No es lifecycle de pentesting ni control standard.
OWASP SCSVS/SCSTG/SCWE	Requisitos, pruebas y debilidades de smart contracts/dApps	Cobertura parcial de CEX, custodia operativa, nodos, L2, cloud y reservas.
EEA EthTrust v3	Requisitos y profundidad de revisión Solidity	Solidity-centric; no whole-system assessment.

Fuente	Fortaleza	Límite principal
NIST SP 800-115	Proceso disciplinado de assessment	No especializado en irreversibilidad, composabilidad o incentivos.
Investigación académica	Código, secuencias, MEV, DeFi y bridges	Hallazgos distribuidos; no engagement framework completo.

5. Análisis de brecha

La revisión identificó seis brechas de integración.

- Objeto incompleto:** la mayoría de las fuentes se concentra en una capa. El riesgo real puede atravesar frontend, firma, API, contrato, oráculo, bridge y tesorería.
- Autorización insuficientemente especializada:** una guía genérica de pentesting no siempre contempla gas, finality, MEV, fondos, balances, reconciliación o terceros on-chain.
- Evidencia no normalizada:** los resultados pueden ser declarativos, documentales, de configuración, observados, adversariales o independientemente reproducidos.
- Riesgo crypto-económico:** confidencialidad, integridad y disponibilidad no capturan por sí solas pérdida financiera, gobernanza, contagio e irreversibilidad.
- Resiliencia y recuperación:** existe mayor atención a prevención que a contención, pausa, recuperación de claves, reconciliación y comunicación.
- Trazabilidad operable:** faltan catálogos comunes que conecten dominio, control, test, amenaza, debilidad, evidencia y finding en formatos legibles por humanos y máquinas.

CSPTF responde a estas brechas mediante integración, no mediante sustitución. El framework remite a las fuentes especializadas para el detalle y añade un modelo común de engagement y evidencia.

6. Principios de diseño

CSPTF se rige por ocho principios: autorización antes que técnica; fork/testnet antes que producción; ausencia de activos de clientes por defecto; invariantes y flujos de valor antes que etiquetas; impacto económico y sistémico como dimensiones de primera clase; evidencia y reproducibilidad; automatización subordinada a validación experta; y divulgación responsable como componente de calidad.

La unidad de evaluación es un grafo del sistema. Sus nodos representan activos, actores, componentes, identidades, contratos, wallets, servicios e infraestructuras. Sus aristas representan flujos de valor, datos, autoridad, mensajes y dependencias. Este modelo evita que el alcance dependa únicamente de una lista de IP o repositorios.

7. Arquitectura de veinte dominios

La arquitectura CSPTF contiene veinte dominios: gobernanza; arquitectura; criptografía; gestión de claves; contratos; dApps; tokens; DeFi; oráculos; bridges; consenso y nodos; Layer 2; exchanges centralizados; APIs; infraestructura; identidad; supply chain; privacidad y cumplimiento; monitoreo; y respuesta/recuperación.

Los dominios no son silos. Un escenario de drenaje, por ejemplo, puede comenzar con compromiso de identidad, obtener una sesión privilegiada, modificar un pipeline, desplegar una actualización, alterar un signer y evadir monitoreo. La selección de dominios se deriva del sistema modelado y no de una checklist universal.

Cada dominio incluye ocho controles, doce pruebas, cinco amenazas y cinco debilidades. Los identificadores son estables y no codifican severidad. Esta estructura permite trazar un finding a su propiedad esperada, test, evidencia, amenaza y causa.

CSPTF: arquitectura de 20 dominios

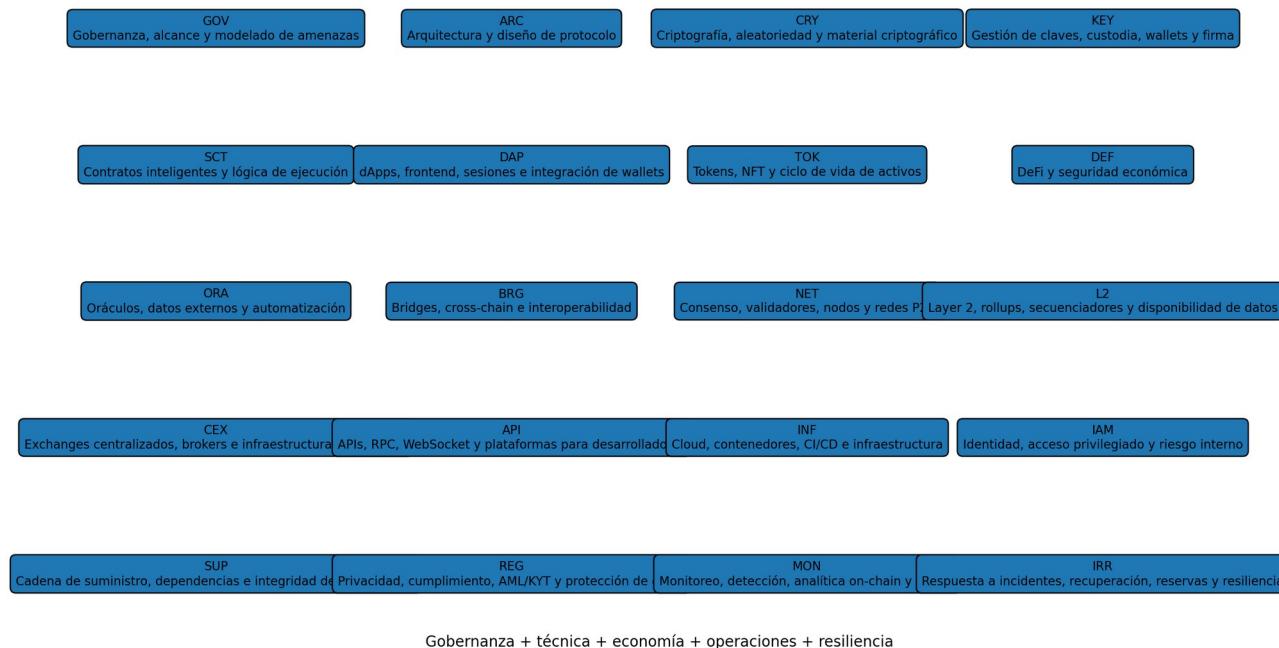


Figura 2. Arquitectura de veinte dominios CSPTF.

ID	Código	Dominio
01	GOV	Gobernanza, alcance y modelado de amenazas
02	ARC	Arquitectura y diseño de protocolo
03	CRY	Criptografía, aleatoriedad y material criptográfico
04	KEY	Gestión de claves, custodia, wallets y firma
05	SCT	Contratos inteligentes y lógica de ejecución
06	DAP	dApps, frontend, sesiones e integración de wallets
07	TOK	Tokens, NFT y ciclo de vida de activos
08	DEF	DeFi y seguridad económica
09	ORA	Oráculos, datos externos y automatización
10	BRG	Bridges, cross-chain e interoperabilidad
11	NET	Consenso, validadores, nodos y redes P2P
12	L2	Layer 2, rollups, secuenciadores y disponibilidad de datos
13	CEX	Exchanges centralizados, brokers e infraestructura de mercado
14	API	APIs, RPC, WebSocket y plataformas para desarrolladores
15	INF	Cloud, contenedores, CI/CD e infraestructura
16	IAM	Identidad, acceso privilegiado y riesgo interno
17	SUP	Cadena de suministro, dependencias e integridad de construcción

ID	Código	Dominio
18	REG	Privacidad, cumplimiento, AML/KYT y protección de datos
19	MON	Monitoreo, detección, analítica on-chain y fraude
20	IRR	Respuesta a incidentes, recuperación, reservas y resiliencia

8. Ciclo de evaluación

El ciclo CSPTF tiene doce fases. Comienza con autorización y gobierno; continúa con descomposición del sistema, threat intelligence y diseño de pruebas; avanza hacia revisión no invasiva, validación adversarial controlada, simulación económica/protocolaria y validación segura en ambientes aislados; incorpora detección y respuesta; y termina con reporte, remediación, retest y aseguramiento continuo.

Cada transición incluye un gate. Por ejemplo, ninguna prueba activa se ejecuta antes de aprobar la matriz de tests, límites y criterios de detención. Ningún finding se reporta como validado sin evidencia revisada. Ningún cierre se declara sin retest o aceptación formal del riesgo residual.

Ciclo de evaluación CSPTF

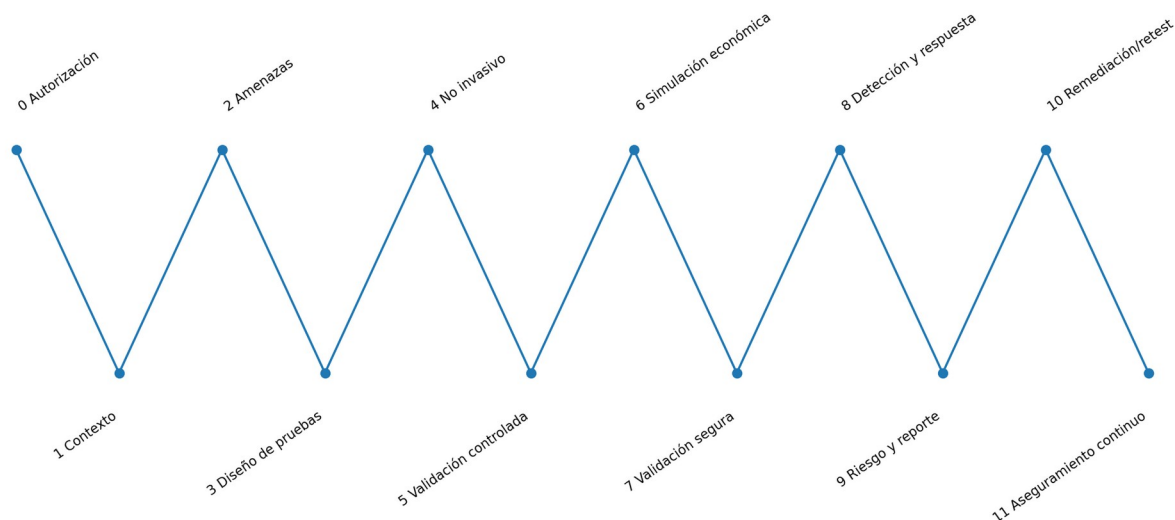


Figura 3. Ciclo de evaluación CSPTF con gates de autorización, evidencia y cierre.

9. Reglas de compromiso y seguridad

El framework ordena los ambientes desde revisión estática hasta producción activa. El assessor debe utilizar el ambiente más seguro que permita responder la pregunta. Una prueba en mainnet o producción solo se justifica cuando revisión, laboratorio, fork, testnet y staging son insuficientes, y cuando el valor adicional supera el riesgo.

Las pruebas activas exigen autorización individual por ID, owner, stop authority, canal de monitoreo, límites de transacciones, gas, volumen y tiempo, balance reconciliation y procedimiento de incidente. Por defecto se prohíben uso de fondos reales de clientes, destrucción, manipulación de mercado, disrupción de consenso, persistencia no controlada y acceso a datos ajenos al objetivo.

La seguridad operacional no es una sección administrativa. En sistemas irreversibles constituye una propiedad técnica del engagement.

10. Perfiles de aseguramiento y evidencia

CSPTF define cuatro perfiles. AP1 Baseline cubre sistemas de baja complejidad y exige evidencia de configuración. AP2 Enhanced añade testing dinámico y revisión independiente del implementador. AP3 Critical se orienta a custodia, CEX, bridges, validadores y DeFi material, con simulación y equipo

especializado independiente. AP4 Systemic exige revisión multi-equipo, ejercicios de crisis y modelado económico/sistémico.

La evidencia se clasifica de E0 a E5: declarativa, documental, configuración, observada, adversarial e independiente. La confianza se reporta por separado en niveles C1-C4. Un finding puede tener alto impacto potencial y baja confianza; ocultar esta diferencia crea una falsa precisión.

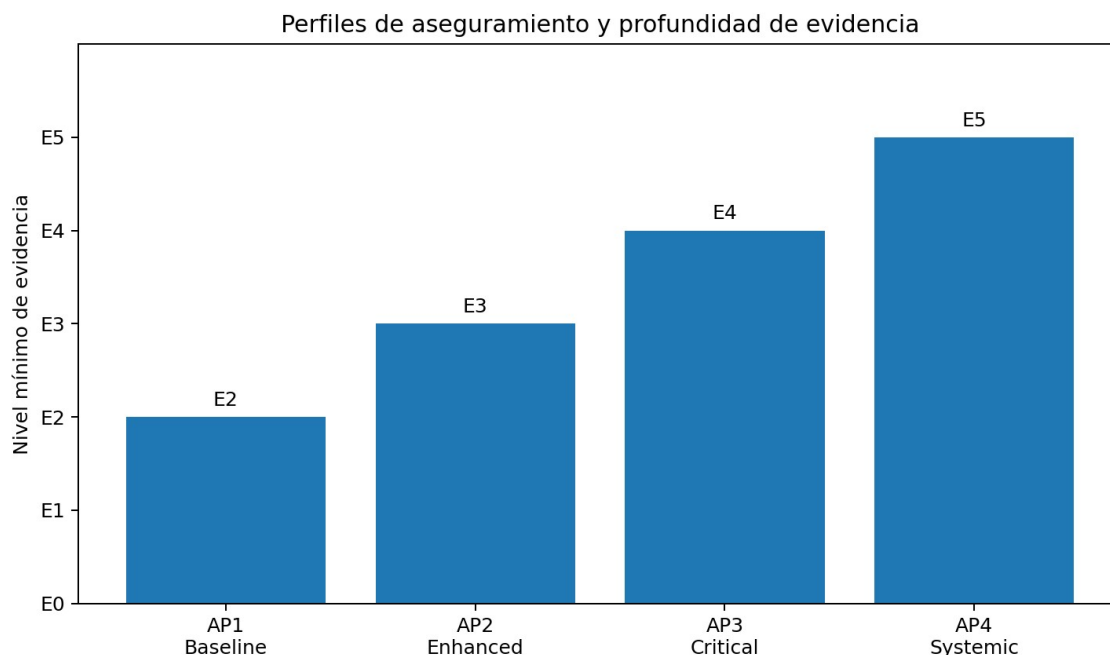


Figura 4. Relación mínima propuesta entre perfil y evidencia.

Perfil	Nombre	Evidencia mínima	Profundidad
AP1	Baseline	E2	Revisión y validación funcional acotada
AP2	Enhanced	E3	Testing dinámico threat-informed
AP3	Critical	E4	Simulación, property testing y ejercicios de falla
AP4	Systemic	E5	Revisión multi-equipo, crisis y modelado sistémico

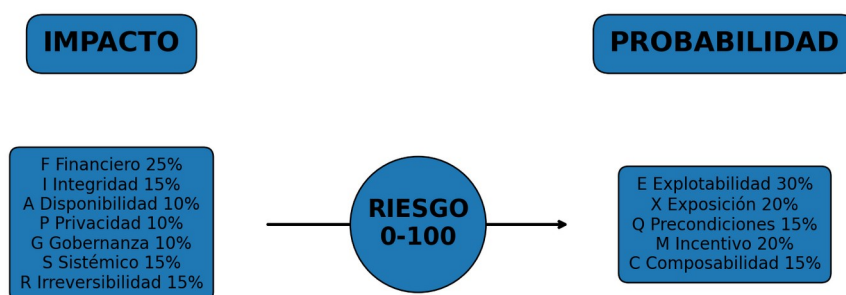
11. Modelo preliminar de riesgo

El impacto combina siete dimensiones: financiera, integridad, disponibilidad, privacidad, gobernanza, sistémica e irreversibilidad. La probabilidad combina explotabilidad, exposición, precondiciones, incentivo y composabilidad. El resultado es una escala 0-100 con bandas informativa, baja, media, alta, crítica y sistémica.

La fórmula es deliberadamente transparente y versionada. No pretende demostrar una exactitud estadística inexistente. Sus pesos deben calibrarse con incidentes, pérdidas, downtime, usuarios afectados, contagio y tiempos de recuperación. La confianza y la calidad de evidencia permanecen separadas del riesgo.

CSPTF desaconseja promediar hallazgos en un único “security score”. Un promedio puede ocultar una clave raíz comprometible o un mint irrestricto. El reporte debe conservar riesgo máximo, concentración, causas compartidas, dependencias correlacionadas e incertidumbre.

Modelo de riesgo crypto-económico CSPTF



RawRisk = $100 \times \text{Impact}/5 \times \text{Likelihood}/5$; score = floor(RawRisk + 0.5).
Modelo v0.1 sujeto a calibración; riesgo y confianza se reportan por separado.

Figura 5. Modelo preliminar de riesgo crypto-económico.

$$\text{Impact} = 0.25F + 0.15I + 0.10A + 0.10P + 0.10G + 0.15S + 0.15R$$

$$\text{Likelihood} = 0.30E + 0.20X + 0.15Q + 0.20M + 0.15C$$

$$\text{RawRisk} = 100 \times (\text{Impact} / 5) \times (\text{Likelihood} / 5)$$

$$\text{Risk} = \text{floor}(\text{RawRisk} + 0.5)$$

Ejemplo: Impact=3.90 y Likelihood=3.75 producen Risk=59, banda Alta.

12. Catálogos y automatización

La versión v0.1 publica catálogos JSON, CSV y Markdown. Los objetos incluyen 20 dominios, 160 controles, 240 tests, 100 amenazas y 100 debilidades. JSON Schema valida estructura; herramientas locales verifican IDs, conteos, referencias y archivos individuales; y un generador produce checklists por perfil y dominio.

La automatización mejora consistencia, pero no determina verdad técnica. Un scanner output es evidencia de configuración o herramienta, no prueba automática de explotabilidad. La experiencia empírica con analizadores de contratos muestra cobertura y falsos positivos variables [19]. Por tanto, CSPTF exige contextualizar reachability, precondiciones, invariantes e impacto.

Objeto	Cantidad	Función
Dominios	20	Sistema y alcance
Controles	160	Propiedades normativas
Pruebas	240	Validación autorizada
Amenazas	100	Escenarios adversarios
Debilidades	100	Causas o condiciones facilitadoras

13. Ejemplo de aplicación

Considérese un bridge ficticio desplegado en una testnet privada. El sistema se modela con contratos en dos cadenas, relayer, validadores, wrapped asset, API de observabilidad y claves administrativas. Se seleccionan ARC, CRY, KEY, SCT, BRG, INF, IAM, MON e IRR.

La evaluación define como invariantes: cada mensaje se procesa una sola vez; el supply wrapped corresponde a activos bloqueados; una reorganización no produce doble release; y un compromiso parcial de validadores no supera el quorum. Los tests se ejecutan en un fork determinístico con activos sintéticos. La evidencia incluye configuración, bytecode, logs, IDs de mensajes, balances antes/después y resultados de simulación.

Si un reset del relayer permite reprocesar un mensaje sintético, el finding se asocia con CSPTF-TEST-BRG, el control de autenticidad/unicidad, la amenaza de replay y la debilidad de persistencia insuficiente. La remediación se valida repitiendo el escenario y pruebas adyacentes. El ejemplo ilustra trazabilidad, no una técnica contra un bridge real.

14. Validación propuesta

La calidad del framework debe evaluarse en seis etapas. La primera mide validez de contenido mediante paneles de expertos. La segunda revisa los mapeos. La tercera aplica estudios de caso retrospectivos y evaluaciones autorizadas. La cuarta mide confiabilidad entre evaluadores. La quinta calibra el scoring con datos de incidentes. La sexta evalúa usabilidad, costo y cobertura.

Antes de v1.0 se requiere comentario público resuelto, revisión independiente de dominios críticos, casos de estudio documentados, estabilidad de identificadores y revisión legal/ética. Si el modelo numérico no demuestra confiabilidad suficiente, deberá simplificarse en lugar de conservar una precisión aparente.

15. Limitaciones y amenazas a la validez

El borrador tiene limitaciones. La revisión no es todavía una systematic literature review registrada. El autor inicial introduce riesgo de sesgo de selección y diseño. Los mapeos v0.1 son temáticos. Los pesos de riesgo no están calibrados. Las cadenas y protocolos evolucionan más rápido que una versión estática. Algunas pruebas dependen de información interna que no existe en auditorías black-box. Finalmente, la amplitud puede generar carga excesiva si no se realiza tailoring.

Estas limitaciones se mitigan mediante transparencia, source register, machine-readable catalogs, gobernanza abierta, estados de mapping, perfiles de aseguramiento y un roadmap explícito de validación.

16. Conclusión

CSPTF propone una metodología integrada para pentesting autorizado de activos digitales. Su contribución no es una nueva lista de bugs, sino una estructura que conecta sistema, amenaza, control, test, evidencia, riesgo, finding, remediación y retest.

La versión v0.1 proporciona una base publicable y reproducible, pero se presenta deliberadamente como borrador. La adopción responsable depende de revisión experta, estudios de caso, calibración y colaboración abierta. En un ecosistema donde los errores pueden ser irreversibles y contagiosos, la madurez del testing debe medirse tanto por su capacidad de descubrir fallos como por su capacidad de hacerlo sin crear daño.

Declaración de estado

CSPTF v0.1.0-draft es una propuesta metodológica abierta. No constituye certificación, garantía de seguridad, cumplimiento automático ni autorización para ejecutar pruebas. Los pesos de riesgo y los mapeos requieren validación independiente.

Referencias

- [1] **MITRE (2025)**. MITRE AADAPT: Adversarial Actions in Digital Asset Payment Technologies. MITRE. <https://aadapt.mitre.org/>
- [2] **MITRE (2025)**. MITRE Introduces AADAPT Cybersecurity Framework for Cryptocurrency. MITRE. <https://www.mitre.org/news-insights/news-release/mitre-introduces-aadapt-cybersecurity-framework-cryptocurrency>
- [3] **OWASP Foundation (2026)**. OWASP Smart Contract Security Testing Guide (SCSTG). OWASP SCS. <https://scs.owasp.org/SCSTG/>
- [4] **OWASP Foundation (2026)**. OWASP Smart Contract Security Verification Standard (SCSVS). OWASP SCS. <https://scs.owasp.org/SCSVS/>
- [5] **OWASP Foundation (2026)**. OWASP Smart Contract Weakness Enumeration (SCWE). OWASP SCS. <https://scs.owasp.org/SCWE/>
- [6] **Enterprise Ethereum Alliance (2025)**. EEA EthTrust Security Levels Specification Version 3. EEA. <https://entethalliance.org/specs/ethtrust-sl/v3/>
- [7] **Scarfone, Souppaya, Cody, Orebaugh (2008)**. NIST SP 800-115: Technical Guide to Information Security Testing and Assessment. NIST. <https://doi.org/10.6028/NIST.SP.800-115>

- [8] **NIST (2024)**. Cybersecurity Framework 2.0. NIST. <https://doi.org/10.6028/NIST.CSWP.29>
- [9] **Yaga, Mell, Roby, Scarfone (2018)**. NISTIR 8202: Blockchain Technology Overview. NIST. <https://doi.org/10.6028/NIST.IR.8202>
- [10] **NIST (2023)**. FIPS 186-5: Digital Signature Standard. NIST. <https://doi.org/10.6028/NIST.FIPS.186-5>
- [11] **NIST (2022)**. SP 800-218: Secure Software Development Framework (SSDF). NIST. <https://doi.org/10.6028/NIST.SP.800-218>
- [12] **MITRE (2026)**. MITRE ATT&CK. MITRE. <https://attack.mitre.org/>
- [13] **MITRE (2026)**. MITRE D3FEND. MITRE. <https://d3fend.mitre.org/>
- [14] **OWASP Foundation (2026)**. OWASP Web Security Testing Guide. OWASP. <https://owasp.org/www-project-web-security-testing-guide/>
- [15] **Atzei, Bartoletti, Cimoli (2017)**. A Survey of Attacks on Ethereum Smart Contracts (SoK). POST 2017. https://doi.org/10.1007/978-3-662-54455-6_8
- [16] **Luu, Chu, Olickel, Saxena, Hobor (2016)**. Making Smart Contracts Smarter. ACM CCS 2016. <https://doi.org/10.1145/2976749.2978309>
- [17] **Tsankov et al. (2018)**. Securify: Practical Security Analysis of Smart Contracts. ACM CCS 2018. <https://doi.org/10.1145/3243734.3243780>
- [18] **Nikolic et al. (2018)**. Finding The Greedy, Prodigal, and Suicidal Contracts at Scale. ACSAC 2018. <https://doi.org/10.1145/3274694.3274743>
- [19] **Durieux, Ferreira, Abreu, Cruz (2020)**. Empirical Review of Automated Analysis Tools on 47,587 Ethereum Smart Contracts. ICSE 2020. <https://doi.org/10.1145/3377811.3380364>
- [20] **Daian et al. (2020)**. Flash Boys 2.0: Frontrunning in Decentralized Exchanges, Miner Extractable Value, and Consensus Instability. IEEE S&P 2020. <https://doi.org/10.1109/SP40000.2020.00040>
- [21] **Qin et al. (2021)**. Attacking the DeFi Ecosystem with Flash Loans for Fun and Profit. Financial Cryptography 2021. https://doi.org/10.1007/978-3-662-64331-0_1
- [22] **Su et al. (2021)**. Evil Under the Sun: Understanding and Discovering Attacks on Ethereum Decentralized Applications. USENIX Security 2021. <https://www.usenix.org/conference/usenixsecurity21/presentation/su>
- [23] **So, Hong, Oh (2021)**. SmartTest: Effectively Hunting Vulnerable Transaction Sequences in Smart Contracts. USENIX Security 2021. <https://www.usenix.org/conference/usenixsecurity21/presentation/so>
- [24] **He et al. (2021)**. EOSAFE: Security Analysis of EOSIO Smart Contracts. USENIX Security 2021. <https://www.usenix.org/conference/usenixsecurity21/presentation/he-ningyu>
- [25] **Liao et al. (2024)**. SmartAxe: Detecting Cross-Chain Vulnerabilities in Bridge Smart Contracts via Fine-Grained Static Analysis. arXiv. <https://arxiv.org/abs/2406.15999>
- [26] **Augusto et al. (2024)**. XChainWatcher: Monitoring and Identifying Attacks in Cross-Chain Bridges. arXiv. <https://arxiv.org/abs/2410.02029>
- [27] **Wu et al. (2024)**. Safeguarding Blockchain Ecosystem: Understanding and Detecting Attack Transactions on Cross-chain Bridges. arXiv. <https://arxiv.org/abs/2410.14493>
- [28] **OASIS (2024)**. STIX Version 2.1. OASIS Open. <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [29] **FIRST (2023)**. Common Vulnerability Scoring System Version 4.0. FIRST. <https://www.first.org/cvss/v4.0/>
- [30] **OpenSSF (2026)**. Supply-chain Levels for Software Artifacts (SLSA). OpenSSF. <https://slsa.dev/>
- [31] **OWASP Foundation (2026)**. CycloneDX Specification. OWASP. <https://cyclonedx.org/specification/overview/>
- [32] **FATF (2021)**. Updated Guidance for a Risk-Based Approach to Virtual Assets and VASPs. FATF. <https://www.fatf-gafi.org/en/publications/Fatfrecommendations/Guidance-rba-virtual-assets-2021.html>
- [33] **European Union (2023)**. Regulation (EU) 2023/1114 on Markets in Crypto-assets (MiCA). EUR-Lex. <https://eur-lex.europa.eu/eli/reg/2023/1114/oj>
- [34] **European Union (2022)**. Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA). EUR-Lex. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj>
- [35] **Bitcoin Improvement Proposals (2026)**. BIP-32: Hierarchical Deterministic Wallets. Bitcoin BIPs. <https://github.com/bitcoin/bips/blob/master/bip-0032.mediawiki>
- [36] **Bitcoin Improvement Proposals (2026)**. BIP-39: Mnemonic code for generating deterministic keys. Bitcoin BIPs. <https://github.com/bitcoin/bips/blob/master/bip-0039.mediawiki>
- [37] **Ethereum Improvement Proposals (2026)**. EIP-712: Typed structured data hashing and signing. Ethereum EIPs. <https://eips.ethereum.org/EIPS/eip-712>

- [38] **Ethereum Improvement Proposals (2026)**. ERC-1967: Proxy Storage Slots. Ethereum EIPs.
<https://eips.ethereum.org/EIPS/eip-1967>
- [39] **Satoshi Nakamoto (2008)**. Bitcoin: A Peer-to-Peer Electronic Cash System. Bitcoin.org.
<https://bitcoin.org/bitcoin.pdf>
- [40] **Gavin Wood et al. (2026)**. Ethereum Yellow Paper. Ethereum.
<https://ethereum.github.io/yellowpaper/paper.pdf>